

Deliverable 2 — Intelligence Gathering · Détection précoce IT → OT, Marine Nationale

Joseph W. · 12 mai 2026 · Mission briefing, pas un rapport académique

A · The OSINT Framework

Source Mapping — d'où vient l'intel

- **MITRE ATT&CK** (STIX/TAXII) — taxonomie des tactics/TTPs, base pour modéliser les kill chains
- **NVD / NIST CVE feeds** — vulnérabilités, scores CVSS, matching CPE actif↔CVE
- **CISA KEV** (*Known Exploited Vulnerabilities*) — filtre du bruit : seules les CVE *réellement* exploitées dans la nature
- **ANSSI CERT-FR** — bulletins souverains, alertes ciblant la défense FR (priorité doctrine)
- **Doctrine publique ComCyber** — Revue stratégique 2022, REX FREMM/FDI — cadre l'intention métier
- **GitHub PoC repos** — maturité d'un exploit (publié ? armé ? livré ?)
- **Vendor advisories** — Microsoft MSRC, Apache, Pulse Secure — détails techniques de remédiation
- **Threat intel** — Sekoia.io blog, BleepingComputer, abuse.ch — campagnes en cours (Sandworm, CyberAv3ngers)

Tooling — et pourquoi *celui-là* pour cette cible

- **Python + NetworkX** — la cible **est** un graphe (10k nœuds, 20k arêtes) ; NetworkX = natif, sans stack distribuée superflue
- **Neo4j** — format source ; requêtes Cypher pour traversées multi-sauts, valide aussi sans serveur (CSV)
- **pandas + regex** — parsing des descriptions d'événements pour le SemanticMapper
- **Plotly + ipywidgets** — dashboard interactif *sans* déploiement web (souveraineté)
- **nvdlib / cve-search** — enrichissement automatisé CVE → CPE → asset
- **MITRE Navigator** — visualisation des chaînes d'attaque ATT&CK

Pourquoi pas Spark/Elastic ? Volume modeste, on évite la sur-ingénierie. **Pourquoi tout open-source ?** Compatibilité doctrine défense + reproductibilité audit.

B · Dataset Inventory — The Gold

Dataset	Provenance	Freshness	Signal — so what?
neo4j_dataset_50k · 65 actifs IT/OT, 50 k events, 1 attaque	Fourni · Marine Nationale	Snapshot 1 mai 2026	Cas d'école Purdue avec ground truth d'attaque (CVE-2021-41773, 11h-15h) → baseline de validation des détecteurs
generalisation/ · 9 855 actifs, 1 000 CVE/TTP, 2 000 events, 15 processus	Fourni · Marine Nationale	Snapshot 12 mai 2026	Graphe à l'échelle SI + dimension métier → simulation cascade et impact processus à grande échelle
MITRE ATT&CK Enterprise Matrix	attack.mitre.org · STIX/TAXII	Actualisation continue (v15.1)	Référentiel kill chain → permet de chaîner les TTP de la base par phase (<code>simulate_attack_chain</code>)
NVD CVE feeds	nvd.nist.gov · JSON quotidien	Daily	Score CVSS + CPE matching → filtre des targets non-applicables (asset non-vulnérable au CPE)
CISA KEV catalog	cisa.gov/kev · CSV quotidien	Daily, ~1 100 entries	Priorisation : focus sur les CVE de la base déjà observées <i>in the wild</i>
Bulletins CERT-FR (ANSSI)	cert.ssi.gouv.fr	Hebdomadaire	Souveraineté + contexte FR/défense — alertes ciblées sur l'OIV/OSE

C · Intelligence Gaps & Risks — what we don't know yet

Missing link (le trou)	Mitigation — proxy/contournement
Cartographie SI ↔ Métier (MOA) . Aucune arête asset → process dans la base.	<code>SyntheticMOAMapper</code> : combine PageRank (hubs polyvalents), signal sémantique des events, et distribution-cible métier réaliste (28 % Flottes, 22 % Maintenance, 3 % Douanes...).
Transitions TTP→TTP validées . Tactics présentes mais pas les enchaînements canoniques.	Rejeu séquentiel sur l'ordre standard de la kill chain ATT&CK + lateral movement aléatoire entre phases (<code>simulate_attack_chain</code>).
État de patch réel par actif . Pas de calendrier de correctifs déployés.	<code>generate_patch_schedule</code> : modèle probabiliste — critical 30-90j, high 90-180j, medium 180-365j, low 365-730j.
Vérification CPE ↔ CVE . Table targets prise pour argent comptant sans validation de vulnérabilité.	Phase 3 : enrichissement <code>nvdlib</code> pour vérifier que l'asset.cpe matche le CPE de la CVE — filtre les fausses cibles.
Attribution / threat intel campagnes . Aucune info sur l'acteur (APT, criminel, hacktiviste).	Croisement CISA KEV + MITRE Groups (Sandworm, CyberAv3ngers) en post-traitement — info contextuelle, non bloquante pour la détection.

TL;DR L'intel (CVE, TTP, CVSS, CPE) est solide et publique. L'intel (cartographie SI ↔ processus) manque — mais on a un *proxy crédible* qui se substituera en 10 lignes le jour où la MOA fournit la vraie carto.

Sources : NVD · MITRE ATT&CK v15.1 · CISA KEV · ANSSI CERT-FR · Doctrine ComCyber 2022 · datasets fournis Marine Nationale